Práctica 3. Auditoría Integral de Sistemas Inteligentes: Casos Reales (1 punto)

Importante:

1. Realizad la práctica en los mismos grupos de 3 personas que en las prácticas anteriores (P01 y P02).
2. Cada grupo trabajará únicamente sobre uno de los sistemas inteligentes propuestos, que será asignado por el profesorado.
3. Todos los integrantes del equipo deben estar familiarizados con la totalidad de los ejercicios de la práctica.
4. Importante: No incluyáis en la memoria descripciones o conceptos que no comprendáis. Consultad cualquier duda con el profesor de prácticas.

Diseño del sistema y delimitación del alcance (20 %)

1. **Caracterización funcional del sistema asignado**
   - Analizad el sistema asignado y determinad si su diseño actual permitiría iniciar un despliegue controlado desde el punto de vista de auditoría.
   - Identificad la finalidad prevista del sistema, sus entradas, sus salidas y el tipo de decisión o apoyo a la decisión que realiza.
   - Delimitad con precisión qué componentes quedan dentro del alcance de la pre-auditoría y cuáles quedan fuera.
   - Identificad incoherencias, lagunas o contradicciones en el diseño o en la documentación del sistema proporcionado.
2. **Actores, ciclo de vida y evidencias mínimas**
   - Identificad los actores principales implicados en el sistema: proveedor, integrador, organización usuaria, operador humano, mantenedor y personas o colectivos potencialmente afectados.
   - Elaborad un mapa simplificado del ciclo de vida del sistema, incluyendo al menos: datos, entrenamiento o ajuste, validación, despliegue, operación y mantenimiento.
   - Indicad qué evidencias mínimas deberían existir en cada una de esas fases para que el sistema pudiera ser considerado auditable.

Evaluación ética y cumplimiento preliminar (35 %)

3. **Análisis ético aplicado y tensiones**
   - Analizad el sistema utilizando la lógica principio $\rightarrow$ riesgo $\rightarrow$ pregunta de auditoría $\rightarrow$ evidencia.
   - Como mínimo, debéis evaluar los siguientes ejes:
     - supervisión humana,
     - privacidad y gobernanza de datos,
     - transparencia/explicabilidad,

    - equidad/no discriminación,
    - responsabilidad,
    - seguridad y prevención del daño.
- Indicad qué decisiones del sistema deberían poder ser revisadas o cuestionadas por un operador humano y en qué condiciones.
- Señalad qué información debería comunicarse a usuarios, operadores o personas afectadas para que el sistema pudiera considerarse mínimamente transparente.
- Justificad qué aspectos del sistema presentan mayor tensión entre utilidad operativa, seguridad, privacidad, equidad o supervisión humana.

4. **Clasificación regulatoria preliminar**

    - Evaluad el sistema asignado desde el punto de vista del cumplimiento preliminar y de la aceptabilidad ética, aplicando las metodologías vistas en clase.
    - Realizad una clasificación regulatoria preliminar del sistema y justificad por qué se trata de un sistema especialmente sensible o crítico en su contexto de uso.
    - Dentro de la clasificación regulatoria, seleccionad 4–5 obligaciones o requisitos especialmente relevantes y decid qué evidencia permitiría verificarlos.

Robustez, seguridad y dictamen final (45 %)

5. **Registro integrado de riesgos, amenazas, controles y evidencia**

    - Construid una pre-auditoría técnica del sistema asignado desde la perspectiva de robustez, seguridad y resiliencia.
    - Elaborad un registro mínimo de 6 riesgos. Para cada riesgo, indicad:
        - tipo de riesgo: accidental o funcional, adversario, ético o de gobernanza,
        - fase del ciclo de vida en la que se manifiesta,
        - activo afectado,
        - actor adversario o fuente de fallo,
        - superficie de ataque o punto de vulnerabilidad,
        - amenaza o escenario de fallo principal,
        - impacto principal,
        - nivel de criticidad,
        - responsable principal de mitigación.
    - El registro deberá incluir obligatoriamente:
        - al menos 2 riesgos accidentales o funcionales,
        - al menos 2 riesgos adversarios,
        - al menos 2 riesgos éticos o de gobernanza con impacto operativo.
    - Para cada riesgo, proponed al menos un control técnico, organizativo o procedimental.
    - Para cada control, indicad qué evidencia sería necesaria para verificarlo y clasificad el estado de dicha evidencia como:
        - evidencia ausente,
        - evidencia insuficiente,
        - evidencia no verificable,

    - evidencia suficiente.
  - Cerrad el apartado señalando cuáles son los riesgos residuales más relevantes que permanecerían incluso después de aplicar los controles propuestos.

6. **Dictamen final de despliegue**
   - Emitid un dictamen final sobre el sistema, eligiendo una de estas tres opciones:
     - Apto para despliegue
     - Apto solo con condiciones previas
     - No apto para despliegue
     - Si se considera que la evidencia disponible no permite emitir una opinión concluyente, justificadlo y asimiladlo a 'No apto para despliegue' o 'Apto solo con condiciones previas', según el caso.
   - Justificad el dictamen final mediante:
     - 3 hallazgos principales,
     - el riesgo residual más relevante,
     - y 3 acciones prioritarias que deberían implantarse antes del despliegue.

Entrega:

- Fecha límite de entrega: **viernes, 15 de mayo de 2026, a las 23:59 h**.
- Entrega a través del Campus Virtual (Moodle). Solo una entrega por grupo.
- Solo se admiten los siguientes archivos:
  - **Memoria** (formato .pdf).
    - Extensión máxima: 4000 palabras (la portada, el índice y el apartado de referencias no cuentan).
    - Nombre: `<GN>_memoria.pdf`. Donde `<GN>` es el número de grupo.
      Por ejemplo: `G2.03_memoria.pdf` para el grupo G2.03.

Evaluación

La evaluación de cada apartado tendrá en cuenta el contenido de la memoria presentada. Es requisito fundamental para obtener una evaluación positiva relacionar las respuestas a cada apartado con el/los temas concretos vistos en las sesiones de teoría.

Adicionalmente, se valorará positivamente la participación en clase, que podrá suponer hasta un 15 % de puntuación adicional.